

Vector Database Security Standard

Mandatory controls for the private RAG stores (Qdrant / Milvus) that hold the enterprise knowledge base, each with the verification it requires.

DOCUMENT AEGIS-SEC-VDB-003 v1.0 · 17 Aug 2026	OWNER Abdullah Zubair Cybersecurity Engineer	PHASE Phase 2 — RAG & Analytics Weeks 5–8	CLASSIFICATION Internal / Confidential
---	--	---	---

1 Why this standard exists

The vector store is the highest-value asset in Aegis: it holds enterprise knowledge in a form that is trivially queryable and trivially leakable. A retrieval bug is not a bug, it is a disclosure. Every control below is mandatory before a production corpus is ingested, and each has a named verification so compliance is demonstrable rather than assumed.

2 Platform controls

ID	REQUIREMENT	VERIFICATION
VDB-01	No public endpoint. Private subnet only, ingress restricted to the gateway and ingestion workers	External port scan returns no reachable service
VDB-02	Authentication enforced on every node (Qdrant API key or JWT, Milvus RBAC users); default open mode explicitly disabled	Unauthenticated request returns 401 in a recorded test
VDB-03	mTLS on the data path and on cluster-internal replication traffic	Handshake without a client certificate is rejected
VDB-04	Encryption at rest for segments, snapshots, and backups using the vector store DEK	Key reference confirmed in the register, AEGIS-SEC-KMS-002
VDB-05	Rate limits and result-size caps per identity, to blunt mass extraction and embedding-inversion probing	Load test shows throttling before the extraction threshold
VDB-06	Backup and restore tested end to end; snapshot access logged and alerted	Timed restore drill into an isolated environment

3 Data-layer controls

ID	REQUIREMENT	VERIFICATION
VDB-07	Every chunk carries access metadata written at ingest time; unlabelled chunks are rejected	Schema validation in the ingestion pipeline
VDB-08	Retrieval is filtered server-side by the caller's RBAC claims. Filtering after retrieval in application code is prohibited	Automated test asserts the filter on every RAG call
VDB-09	Separate collections per sensitivity tier for HR, legal, and finance corpora	Collection inventory reviewed with the Team Lead
VDB-10	Hard-delete path removes vectors, chunks, caches, and derived indexes on document withdrawal	Withdrawn test document is unanswerable within 15 minutes

4 Chunk payload & enforced filter

REQUIRED PAYLOAD AT INGEST

```
{
  "source_uri": "...",
  "content_sha256": "...",
  "classification": "C3",
  "acl_roles": ["finance"],
  "owner": "dept-finance",
  "dlp_pack": "v1.0",
  "ingested_at": "2026-08-17"
}
```

SERVER-SIDE FILTER, EVERY QUERY

```
filter:
  must:
    - key: acl_roles
      match:
        any: $caller.roles
    - key: classification
      match:
        any: $caller.max_class
```

A query that arrives without the filter is rejected and pages the on-call engineer. The same DLP engine runs over documents **before** embedding, so secrets never become vectors — ingest-time classification is what makes the filter above meaningful.

5 Threat cases and required tests

THREAT	TEST	OWNER
Low-privilege user retrieves high-classification chunks	RBAC bypass suite, one case per tier	Jamil Jawed
Prompt injection inside an ingested document redirects the model or exfiltrates context	Poisoned-document corpus with assertions on output	Abdullah Zubair
Cross-tenant similarity leakage from a shared collection	Nearest-neighbour probe across tenants	Swaadesh U.S
Snapshot or backup read without credentials	Direct object-store access attempt	Abdullah Zubair
Withdrawn document still answerable from cache or index	Delete-then-query regression case	Atif Shamim

6 Phase 2 exit conditions

- ☐ All ten controls verified on every cluster, with the verification artefact stored against the control ID
- ☐ The five threat tests running green in CI, not as one-off manual checks
- ☐ Ingest pipeline rejecting unlabelled or unscanned documents by default
- ☐ Every exception recorded in the risk register with an owner and an expiry date

No corpus goes live on an unverified cluster. Where a control cannot be met in Phase 2, the corpus stays out of the store until the exception has a dated remediation plan agreed with the Team Lead.

PREPARED BY Abdullah Zubair Cybersecurity Engineer ----- Signature / date	REVIEWED BY Atif Shamim AI Application Developer ----- Signature / date	APPROVED BY Hrishikesh Reddy Team Lead ----- Signature / date
--	--	--